SIMATS ENGINEERING

Engineer to Excel

SIMATS

Saveetha Institute of Medical And Technical Sciences

(Declared as Deemed to be University under Section 3 of UGC Act 1956)

ITA1439 | CO1 – ASSIGNMENT_1 | ETHICAL HACKING

Assignment Detail	Information
Course Code	**ITA1439**
Course Name	**Ethical Hacking**
Slot	**A**
Nature	**Individual**
Duration	**1 Week**
Total Marks	**50**
Student Name	**K.Dhanush Reddy**
Register Number	**192324087**

TABLE OF CONTENTS

Table 2: Contents

Section	Title
0	Scenario and Design Challenge
1	Task 1 – Enquiry and Framework Blueprint
2	Task 2 – Hacker Threat Model and Classification
3	Task 3 – Ethics and Code-of-Conduct Module
4	Task 4 – Legal-Compliance Mapping
5	Task 5 – Scope and Rules of Engagement
6	Task 6 – Authorization and Disclosure Layer
7	Task 7 – Isolated Ethical-Hacking Lab
8	Task 8 – Reusable Document Library
9	Task 9 – Integrate, Test and Refine
10	Task 10 – Scalability and Governance Evaluation
11	Task 11 – Changed Requirement
12	Conclusion and References

SECTION 0 – SCENARIO AND DESIGN CHALLENGE

Scenario: A university is preparing for a major technology upgrade and needs an Authorized Security-Assessment Programme for its student portal, learning-management system (LMS), email service and campus network. The initial programme covers about 20 systems and 50 staff, with future expansion to the whole university and external third-party assessors. Requests may come from different departments, and tests may be performed by internal or external testers. Some systems hold personal data.

Risks include unauthorized access, legal exposure, damage to live systems, unclear scope and uncoordinated disclosure. The team acts as the Ethical-Hacking Governance Team. This assignment stays at design, documentation and isolated-lab level; no live exploitation is performed.

The framework separates three questions: Is the activity authorized by the owner? Is it legal under applicable law? Is it appropriate, proportionate and safe under professional ethics? A positive answer to one does not automatically answer the others.

Design Challenge

Create an integrated framework covering authorization, scope and Rules of Engagement (RoE), legal compliance, attacker modelling, isolated-lab testing and responsible disclosure. Every major decision needs a reason, supporting evidence and a documented trade-off.

Table 3: Design Challenge Controls

Control Area	Question	Evidence
Authorization	Who can approve?	Signed approval
Scope/RoE	Which assets and methods?	Versioned scope and exclusions
Legal/privacy	Which duties apply?	Legal review and data plan
Threat model	Which actors and assets?	Actor/risk register
Lab	Can checks be tested safely?	Lab configuration and log
Disclosure	Who receives findings and when?	Finding, remediation and closure records

REAL-TIMEEXAMPLE:-
A university may authorize the student portal but exclude a payment gateway operated by a vendor. Even if the gateway is technically reachable, the assessor must stop and obtain separate written approval. Technical access is not authorization.

TASK 1 – FORMULATE THE ENQUIRY AND FRAMEWORK BLUEPRINT

1.1 Scenario-Linked Introduction

Different departments and assessors need one consistent process. The governance team converts the scenario into testable requirements and approval gates.

1.2 Formal Governance Requirements

Table 4: Formal Governance Requirements

Systems in Scope	Stakeholders	Expected Activities	Constraints
Student portal, LMS, email, campus network; about 20 initial systems.	IT/security, system owners, department heads, legal/privacy lead, internal and external assessors.	Asset inventory, risk review, approved assessment, lab validation, findings and remediation.	Written authorization, defined scope, no live exploitation in this assignment, data minimization.
Future university-wide services and vendor systems.	Leadership, procurement, vendors, external assessor manager.	Onboarding, contracts, approvals, access tracking and disclosure.	Third-party owner approval required; least privilege and audit trail.

1.3 Enquiry Questions

1. Who can authorize the assessment and who owns each system?
2. Which domains, IP ranges, applications, dates, accounts and methods are in scope?
3. Which laws, contracts, privacy requirements and incident-reporting duties apply?
4. How will personal data be minimized, stored, retained and deleted?

5. How will critical findings be reported, acknowledged, fixed and closed?
6. What stop conditions apply if availability, privacy or scope is at risk?

1.4 Framework Blueprint

Figure 1: Framework blueprint and approval gates

STEP 1	STEP 2	STEP 3	STEP 4	STEP 5	STEP 6	STEP 7
Request + owner	Written authorization	Scope/RoE + legal review	Threat model	Isolated lab	Finding + disclosure	Remediation + closure

Authorization establishes permission; the RoE limits methods and targets; legal review checks obligations; threat modelling prioritizes risk; the lab validates procedures safely; disclosure routes evidence to the owner. A failed gate blocks the next stage.

1.5 Acceptance Criteria

Table 5: Acceptance Criteria

Criterion	Acceptance Test	Rationale / Trade-off
Authorization	Signed approval exists for every engagement.	Adds time but prevents unauthorized activity.
Scope	Targets and exclusions are explicit and versioned.	More preparation, fewer boundary errors.
Legal/privacy	Data and applicable duties reviewed before testing.	May delay work but reduces exposure.
Safety	Risky checks use isolated lab by default.	Less production realism but less harm.
Traceability	Approvals, findings and status changes are logged.	Extra work supports auditability.
Disclosure	Owner, severity, dates and status recorded.	Deadlines need flexibility but remain visible.

1.6 Rationale

The framework addresses unclear scope, mixed assessor types, personal-data exposure and uncoordinated disclosure. It intentionally accepts some administrative overhead in exchange for safer, defensible testing.

REAL-TIME EXAMPLE

The 2017 Equifax breach is commonly discussed in relation to an unpatched known vulnerability and weaknesses in asset visibility and remediation. The governance lesson is to assign owners, maintain inventories and track security findings through verified closure.

Evidence Produced: Requirements table, enquiry questions, blueprint, acceptance criteria and rationale.

TASK 2 – HACKER THREAT MODEL AND CLASSIFICATION

2.1 Introduction

Different actors may target public services, staff accounts or research information. Classification helps select controls, but labels should be evidence-based rather than assumptions about identity.

2.2 Actor Classification

Table 6: Actor Type, Motivation, Capability and Targets

Actor Type	Motivation	Typical Capability	Likely University Target
White-hat	Improve security with permission.	Structured testing and reporting.	Approved portal/LMS/lab.
Black-hat	Theft, extortion, disruption.	Credential theft, malware, unauthorized access.	Student records and staff email.
Grey-hat	Curiosity or recognition; may lack permission.	Finds and reports flaws but may cross boundaries.	Public portal.
Script kiddie	Attention, experimentation or disruption.	Uses ready-made scripts with limited understanding.	Login pages and exposed services.
Hacktivist	Political/social cause or publicity.	Defacement, leaks, disruption.	Public website and communications.
Insider	Grievance, gain or carelessness.	Misuses legitimate access.	Records, drives, admin tools.
State-sponsored	Strategic intelligence objectives.	Patient, advanced operations.	Research and network infrastructure.

2.3 Classification Criteria

Record authorization status, observable behaviour, likely intent (or unknown), capability level and potential confidentiality, integrity, availability or privacy impact. Use neutral IDs ACT-01, ACT-02 and confidence levels Low/Medium/High. Do not infer identity or criminal intent without evidence.

2.4 Borderline Actor

Case: a student scans the public portal without permission, finds a possible weakness and emails IT, claiming to help.

Table 7: Borderline Actor Alternatives

Alternative	Supporting Reason	Limitation
Grey-hat	Claimed helpful intent and	Intent does not replace

	reporting.	permission.
Unauthorized tester / policy violator	Testing occurred without prior authorization.	Describes observable behaviour without guessing motive.

Final classification: unauthorized tester; claimed defensive intent is recorded but not treated as verified. The grey-hat label may be secondary, but it does not excuse unauthorized activity. The student should stop testing and let the authorized team validate the report.

2.5 Defensive Implications

Insider risks need access reviews and logs; phishing risks need email controls, MFA and awareness; criminal risks require backups, incident response and recovery planning.

REAL-TIMEEXAMPLE:-
The 2022 ransomware incident affecting AIIMS Delhi was reported as a major disruption. The lesson for universities is to protect critical services, maintain tested backups and plan incident escalation. Attribution should not be asserted without reliable evidence.

Evidence Produced: Actor mapping, classification criteria and justified borderline decision.

TASK 3 – ETHICS AND CODE-OF-CONDUCT MODULE

3.1 Introduction

Because assessments may encounter personal data, ethical rules must be explicit and enforceable for all internal and external testers.

3.2 Ethical Principles

Table 8: Ethical Principles

Principle	Required Behaviour	Evidence / Check
Written authorization	Start only after authorized owner signs.	Signed approval ID.
Agreed scope	Use only listed targets, methods and dates.	Versioned scope and RoE.
Confidentiality	Access minimum data; do not share it unnecessarily.	Restricted evidence repository.
Integrity	Do not alter data or settings without approval.	Activity log/change approval.
Avoid harm	Stop if service, privacy or safety is at risk.	Stop condition and escalation log.
Honest reporting	State evidence, uncertainty and limitations accurately.	Reviewed finding report.

3.3 Decision Rules

Table 9: Ethical Decision Rules

Rule	Check	Response
Authorization	No signed or current approval?	Reject or pause.
Scope	Target/method not listed?	Stop and request written change.
Data minimization	Unexpected personal data appears?	Stop collection; notify privacy lead.
Safety	Service degrades or stop condition occurs?	Stop and escalate.
Disclosure	External release requested?	Legal/privacy and owner review.
Evidence integrity	Finding cannot be supported?	Mark unverified; request review.

3.4 Scenario Test Cases

Table 10: Code-of-Conduct Test Cases

Action	Classification	Response
Test in isolated lab with synthetic data and report evidence.	Acceptable	Record and review.
Notice out-of-scope issue and report without probing further.	Borderline but responsible	Request separate approval before follow-up.
Copy student records to personal drive as proof.	Unacceptable	Stop, secure evidence and follow incident process.
Continue after owner says stop.	Unacceptable	Terminate, log and escalate.
Report an unverified issue as confirmed critical.	Unacceptable	Correct report and require evidence review.

3.5 Trust and Professionalism

The module sets consistent expectations, reduces harm and gives owners a fair opportunity to validate findings. Strict controls can slow work, but this is justified where real users and institutional data are at risk.

REAL-TIME EXAMPLE

The Uber 2016 breach was later criticized in relation to the handling and disclosure of the incident. The lesson is to preserve records, escalate promptly and report honestly rather than conceal a security event.

Evidence Produced: Ethical principles, decision rules, scenario cases and trust rationale.

TASK 4 – LEGAL-COMPLIANCE MAPPING

4.1 Introduction

India is the primary setting. Applicable law depends on facts, location, contracts, system ownership and current commencement rules. This is an educational mapping, not legal advice; university counsel should verify the law before operational adoption.

4.2 IT Act, 2000

Table 11: IT Act Provisions and Controls

Provision	General Relevance	Framework Control
Section 43	Specified unauthorized acts involving computer resources may create civil liability, including unauthorized access/copying or disruption.	Written permission, strict scope and no unauthorized copying.
Section 66	Certain Section 43 acts may be criminal when done dishonestly or fraudulently.	Authorization gate, audit trail and escalation.
Section 66C	Identity theft involving fraudulent/dishonest use of password or unique identification feature.	No credential misuse; use synthetic test accounts.
Section 66D	Cheating by personation using computer resources or communication devices.	No impersonation outside approved simulations.
Section 72	Confidentiality/privacy breach in circumstances covered by the provision.	Confidentiality commitments and controlled evidence.
Section 72A	Disclosure of information in breach of lawful contract in circumstances covered by the provision.	Contractual restrictions and approved disclosure.

Penalty note: wording and penalties depend on current statutory text, amendments and facts. This document avoids unverified fixed penalty figures. Counsel should check the latest official India Code text before adopting the framework.

4.3 DPDP Act and CERT-In

Where digital personal data is involved, review the Digital Personal Data Protection Act, 2023, its commencement notifications, rules, exemptions and obligations in force at the time of testing. Minimize access, document purpose and retention, restrict sharing and route suspected incidents to the privacy/legal lead.

CERT-In directions issued under the IT Act may impose incident-reporting and log-retention duties on covered entities. Counsel should verify applicability and current timelines. Preserve logs and escalate suspected reportable incidents promptly.

4.4 Compare with US CFAA

Table 12: Legal Framework Comparison

Framework	Focus	When Relevant	Control
India IT Act, 2000	Computer-related civil liability and offences.	Relevant Indian legal connection.	Authorization, scope, evidence and escalation.
DPDP Act, 2023	Digital personal-data processing within scope.	Engagement handles covered digital personal data.	Data minimization, secure storage and retention.
CERT-In directions	Cyber incident reporting and operational duties for covered entities.	If university/service is covered.	Log preservation and incident triage.
US CFAA, 18 U.S.C. §1030	Certain unauthorized access and computer-related conduct.	Potential US jurisdictional connection; counsel assesses facts.	Jurisdiction review and owner authorization.

4.5 Offences, Obligations and Penalty Review

Table 13: Offences, Obligations and Legal Review

Risk	Framework Obligation	Penalty / Legal Handling
Unauthorized access or damage	No work outside signed scope.	Counsel verifies applicable IT Act provision and current consequences.
Credential/identity misuse	No real credentials unless expressly approved and necessary.	Review Sections 66C/66D where relevant.
Confidentiality/data disclosure	Minimize, encrypt and restrict evidence.	Review Sections 72/72A and data-protection duties.
Incident reporting	Escalate promptly and preserve timestamps/logs.	Check current CERT-In directions and deadlines.
Personal data	Document purpose, access, retention and deletion.	Check DPDP commencement and applicable rules.

4.6 Legal Requirement to Control Mapping

Table 14: Legal Requirements to Controls

Requirement	Control	Evidence
Permission	Signed authorization and expiry.	Approval record.
Scope boundary	Versioned assets and exclusions.	Scope register.
Confidentiality	Access control, retention/deletion schedule.	Repository log.
Incident response	Escalation tree and timeline.	Incident ticket.
Third party	Contract, owner permission and data terms.	Vendor onboarding pack.

4.7 Personal Data Decision

If a system holds personal data, testing must pause until the owner, privacy lead and legal adviser approve a data-handling plan. Prefer synthetic data or a non-production replica. If production access is exceptionally required, define minimum access, evidence rules, storage, retention, deletion and escalation. This sacrifices some realism to protect privacy.

REAL-TIME EXAMPLE

In Van Buren v. United States (2021), the US Supreme Court interpreted the CFAA's 'exceeds authorized access' language in a specific context. It shows that legal boundaries depend on statutory interpretation and facts; it does not grant permission to test systems.

Evidence Produced: Legal mapping, control tables and personal-data decision.

TASK 5 – SCOPE AND RULES OF ENGAGEMENT

5.1 Introduction

A standard RoE clarifies what is allowed, when testing can occur, who can stop it and how unexpected conditions are handled.

5.2 Scope Boundaries

Table 15: Scope Boundaries

Category	Examples	Rule
In scope	Approved portal test tenant, LMS test tenant, email configuration review, designated lab segment.	Exact identifiers and owner must be listed.
Conditional	Production systems or systems with personal data.	Requires explicit approval and privacy/safety controls.
Out of scope	Vendor payment gateway, personal devices/accounts, unrelated domains, unapproved vendor systems.	No testing until separate owner approval.

Prohibited by default	Denial-of-service, destructive actions, persistence, real-user phishing, uncontrolled password guessing, data exfiltration.	Use safe lab alternatives; explicit special approval is not automatic.

5.3 Testing Windows and Escalation

Table 16: Testing Windows and Escalation

RoE Field	Default Rule
Testing window	Weekdays 10:00–16:00 local time unless otherwise signed.
Notice	At least five business days before start.
Emergency stop	Any tester, owner or incident lead may call STOP.
Critical escalation	Immediately contact engagement lead and owner.
Change control	Any change to targets, methods, dates or data requires written approval.
Evidence	Minimum necessary, encrypted, restricted access, retention/deletion documented.

5.4 Authorization Record

- Engagement ID, requesting department, purpose and risk rationale.
- Owner name, role, contact and evidence of authority.
- Exact assets, exclusions and third-party dependencies.
- Permitted/prohibited methods, dates, accounts and stop conditions.
- Data categories, evidence storage, access list and retention.
- Approver signature/date, assessor acknowledgement, version and expiry.

5.5 Naming and Boundary Rules

Use ID UNI-SEC-YYYY-NNN. Tag every asset IN-SCOPE, OUT-OF-SCOPE or PENDING-APPROVAL. Unlisted assets default to OUT-OF-SCOPE. Check aliases, redirects, shared hosting and vendor dependencies; similar names do not establish authorization.

5.6 Pre-Engagement Checklist

Table 17: Pre-Engagement Checklist

Check	Evidence
Signed, current authorization	Approval ID and signature
Owner and emergency contact confirmed	Contact list

Scope/exclusions/testing window agreed	Versioned RoE
Legal/privacy review complete	Review sign-off
Lab/test environment prepared	Configuration record
Backup/rollback and monitoring arranged if needed	Owner confirmation
Evidence storage and retention approved	Access/retention record
Stop conditions understood	Assessor acknowledgement

REAL-TIME EXAMPLE

The 2019 Coalfire/Iowa courthouse tester case is often cited in discussions about scope and authorization. The lesson is to verify the exact site, assets, rules and local requirements before testing; a broad contract should not replace clear operational authorization.

Evidence Produced: RoE tables, authorization rules, naming convention and checklist.

TASK 6 – AUTHORIZATION AND DISCLOSURE LAYER

6.1 Introduction

Approval determines whether work may begin; disclosure controls how findings reach the owner and how fixes are tracked. Both require an auditable record.

6.2 Authorization Workflow

Figure 2: Authorization workflow

STEP 1	STEP 2	STEP 3	STEP 4	STEP 5	STEP 6
Request	Owner/risk review	Legal/privacy review	Written sign-off	Record approval + RoE	Testing gate opens

6.3 Coordinated Disclosure Process

Table 18: Coordinated Disclosure Timeline

Stage	Proposed Target	Action
Report submitted	Day 0	Finding summary, asset, impact, evidence, safe validation and contact.
Acknowledgement	Within 3 business days	Assign finding ID and confirm receipt.
Triage	Within 5 business days after acknowledgement	Validate severity, scope, confidence and owner.
Remediation plan	Within 10 business days for high/critical	Assign fix owner, mitigation and target date.
Remediation	Normally 30–90 days based on severity	Track progress; apply interim mitigation if needed.

Closure	After fix validation	Record residual risk and disclosure decision.

These are proposed internal targets, not universal legal deadlines. Statutory and contractual deadlines take precedence. Critical risks require immediate escalation.

6.4 Disclosure Models

Table 19: Disclosure Model Comparison

Model	Advantages	Limitations	Default
Coordinated disclosure	Allows owner validation and remediation.	Can stall without deadlines.	University default.
Full/public disclosure	May alert affected users and create urgency.	Can expose systems before a fix; legal/privacy risk.	Exception after documented review.
Bug bounty	Structured intake and potential incentives.	Needs clear scope, budget, triage and safe-harbour terms.	Optional later phase.

6.5 Finding Report Format

Table 20: Finding Report Fields

Field	Required Content
Finding ID / engagement ID	Unique IDs linked to approval and RoE.
Asset and owner	Exact in-scope asset and responsible team.
Summary/evidence	Issue, timestamp and minimum necessary evidence.
Severity/confidence	Impact rating and evidence-based confidence.
Safe validation	Approved non-destructive validation or lab evidence.
Recommendation	Practical remediation and verification.
Status/dates	Submitted, acknowledged, triaged, retest, closed.
Disclosure restriction	Recipients and external publication approval status.

6.6 Logging and Decision Rules

- Log approval creation, version changes, expiry, suspension and revocation.
- Record every finding status transition, timestamp, actor and reason.
- Do not publish externally before coordinated review except where law/safety or documented public-interest considerations require it.

- Use coordinated disclosure by default; any exception requires legal, privacy and risk review.
- RoE governs testing boundaries; legal review sets obligations; disclosure governs communication and remediation.

REAL-TIMEEXAMPLE:-
Google Project Zero has used a coordinated disclosure policy with a generally 90-day deadline and documented exceptions. The lesson is to set predictable timelines and escalation rules; the university must adopt its own policy based on risk and law.

Evidence Produced: Authorization workflow, disclosure timetable, comparison and finding template.

TASK 7 – ISOLATED ETHICAL-HACKING LAB

7.1 Introduction

A controlled lab validates procedures without touching live university systems. Use Kali Linux and authorized target VMs on host-only network 192.168.56.0/24.

7.2 Lab Topology

Figure 3: Host-only lab topology (192.168.56.0/24)

STEP 1	STEP 2	STEP 3	STEP 4
Host computer VirtualBox host	Kali VM 192.168.56.10	Target VM A 192.168.56.20	Target VM B 192.168.56.30

All VMs connect to the host-only virtual network. Confirm the actual adapter settings and avoid bridged adapters on target VMs. If internet is needed to update Kali, use a controlled NAT adapter temporarily, then disconnect it before isolated tests.

7.3 Components and Connectivity

Table 21: Lab Components and Connectivity

Component	Role	Example IP	Connectivity
Host computer	Runs virtualization and snapshots.	Host-only adapter may be 192.168.56.1	Host-only segment.
Kali VM	Authorized test workstation/logging.	192.168.56.10	Host-only; NAT only temporarily for approved updates.
Target VM A	Authorized training target.	192.168.56.20	Host-only only.
Target VM B	Second training target.	192.168.56.30	Host-only only.
Virtual switch	Connects lab machines.	192.168.56.0/24	No default route to public internet by design.

7.4 Record Lab Configuration

7. Record virtualization platform/version, VM names, OS versions and snapshot IDs.
8. Record each adapter mode and host-only network CIDR.
9. Record IP addresses and verify target VMs have no bridged adapter.
10. Capture configuration screenshots and store them with the lab record.
11. Create clean snapshots before testing and document restoration steps.

7.5 Safe Operations and Sample Commands

Operation A – inspect network interfaces:

ip addr show

Expected result: interfaces are listed and the lab interface should show the configured host-only address, such as 192.168.56.10/24.

Operation B – check authorized target connectivity:

ping -c 4 192.168.56.20

Expected result: replies appear if the VM is running and ICMP is allowed. No reply may indicate a firewall or configuration issue; it does not prove the target is down.

Operation C – inspect routes:

ip route

Expected result: host-only subnet route appears and there should be no unintended route from target VMs to the university network.

7.6 Host-Only vs NAT

Table 22: Host-Only and NAT

Mode	Benefit	Risk / Limitation	Decision
Host-only	Containment; target VMs are not directly connected externally.	No direct internet access; host is still part of lab boundary.	Use for testing and targets.
NAT	Convenient for approved package updates.	Outbound access can weaken containment if left enabled.	Use temporarily for Kali updates, then disconnect.

7.7 Containment

Host-only networking reduces the chance of reaching production systems; snapshots enable recovery; synthetic data avoids exposing student records; and the lab inventory documents authorized machines. The trade-off is imperfect production realism, so any production validation requires separate authorization.

REAL-TIME EXAMPLE

Hack The Box, TryHackMe and Metasploitable-style practice environments are examples of structured training labs. They let learners practise within defined boundaries rather than

experimenting on public systems.

Evidence Produced: Topology, component table, configuration steps, safe commands and network-mode decision.

TASK 8 – REUSABLE DOCUMENT LIBRARY

8.1 Introduction

Reusable forms standardize requests, scope, findings and closure. Store templates in a controlled repository with versioning and role-based access.

8.2 Authorization Form

Table 23: Authorization Form

Field	Default / Example
Engagement ID	UNI-SEC-2026-001
Department / purpose	[Department] / security assessment before upgrade
System owner	[Name, role, contact]
Assets	[Exact approved asset IDs]
Testing window	[Start/end date/time]
Methods/exclusions	[Approved methods] / [Explicit exclusions]
Data category	Synthetic data preferred; personal data requires review
Approver/signature	[Authorized owner, date]
Expiry/revocation	[Expiry date and contact]

8.3 RoE Sheet

Table 24: RoE Sheet

Field	Default / Example
RoE ID	ROE-UNI-2026-001 v1.0
Engagement link	UNI-SEC-2026-001
In-scope/out-of-scope	Only signed asset list / all unlisted assets
Testing window	Weekdays 10:00–16:00 unless approved otherwise
Stop conditions	Service degradation, unexpected data, scope uncertainty, owner instruction
Escalation	Tester → engagement lead → owner → incident/legal/privacy lead
Evidence	Minimum necessary, encrypted, restricted and retention-controlled

Sign-off	Owner and assessor acknowledgement

8.4 Finding Report

Table 25: Finding Report

Field	Default / Example
Finding ID / engagement ID	FIND-UNI-2026-001 / UNI-SEC-2026-001
Title / asset	[Issue title] / [approved asset]
Severity / confidence	[Low/Medium/High/Critical] / [Low/Medium/High]
Evidence / impact	[Timestamped evidence] / [CIA/privacy impact]
Recommendation	[Specific fix and verification]
Owner / due date	[Team] / [Date]
Status	Submitted → Acknowledged → Triaged → Remediated → Retested → Closed
Disclosure	Internal/coordinated/external approval required

8.5 Structured Output Integration

Table 26: Structured Finding Output

Key	Example	Consumed By
finding_id	FIND-UNI-2026-001	Audit log
engagement_id	UNI-SEC-2026-001	Authorization/RoE cross-check
asset_id	LMS-TEST-01	Scope validator
severity	High	Triage/escalation
status	Acknowledged	Disclosure tracker
due_date	YYYY-MM-DD	Dashboard
evidence_ref	EVID-001	Restricted repository

8.6 Disclosure Notice and Closure Report

Table 27: Disclosure and Closure Templates

Document	Key Fields
Disclosure Notice	Notice ID, finding ID, recipients, acknowledgement target, remediation target, external publication status, next update.
Closure Report	Engagement ID, completed scope, findings by severity/status, exceptions, remediation status, evidence deletion/retention, owner sign-off.

8.7 Template Input Tests

Table 28: Template Input Tests

Input	Class	Expected Result
Mandatory fields complete and signed.	Valid	Accept and generate engagement ID.
Third-party asset included but owner permission pending.	Boundary	Pending Approval; no testing.
Missing signature or expired approval.	Invalid	Reject or suspend.
Finding missing asset ID/evidence.	Incomplete	Return for triage; do not mark confirmed.
Public disclosure requested before owner review.	Restricted	Hold and route to legal/privacy/governance.

8.8 Integration Evidence

The authorization form creates the engagement ID; the RoE links to it; the finding report links to both; the disclosure notice links to the finding; and the closure report records remediation and evidence handling.

REAL-TIME EXAMPLE

Large vulnerability-reporting programmes use standard intake, triage and status tracking. The university can adopt these practices without launching a public bug bounty before it has the legal, financial and staffing capacity.

Evidence Produced: Authorization, RoE, finding, disclosure and closure templates; structured output; input tests.

TASK 9 – INTEGRATE, TEST AND REFINE

9.1 Introduction

This design walkthrough uses a hypothetical LMS test tenant and synthetic data; it does not describe live exploitation.

9.2 Integrated Framework Diagram

Figure 4: Integrated framework

STEP 1	STEP 2	STEP 3	STEP 4	STEP 5	STEP 6	STEP 7
Threat model Task 2	Ethics Task 3	Legal review Task 4	Authorization + RoE Tasks 5–6	Isolated lab Task 7	Templates/findings Task 8	Disclosure/closure

9.3 Walkthrough

12. Department submits LMS security-review request before upgrade.
13. Owner confirms LMS test tenant; production records and vendor services are excluded.
14. Governance team completes threat, legal and privacy review.
15. Owner signs authorization and RoE; engagement ID is recorded.
16. Assessor checks procedures in isolated lab using synthetic accounts and logs setup.
17. A hypothetical issue is documented with evidence, impact, confidence and recommendation.
18. Security team acknowledges the finding and assigns owner and target date.
19. Owner fixes the test environment; authorized retest checks the fix.
20. Closure report records result, exceptions, residual risk and evidence handling.

9.4 Systematic Test Cases

Table 29: Integrated Test Cases

Test	Condition	Expected Behaviour	Pass Criterion
Missing authorization	No signed approval.	Block engagement.	No test scheduled.
Out-of-scope request	Unlisted vendor payment gateway.	Stop and request separate approval.	Scope checker flags out-of-scope.
Legal conflict	Personal data; review incomplete.	Pause production access; use synthetic data.	Legal/privacy gate closed.
Delayed disclosure	Acknowledgement/remediation overdue.	Escalate and record; no silent publication.	Timestamped escalation.
Expired approval	Approval expired.	Suspend until renewed.	Status = Suspended.
Unexpected impact	Test affects unplanned service.	Stop and notify owner.	Incident record exists.

9.5 Problems and Refinements

Table 30: Before-and-After Refinements

Problem	Before	After
Unlisted asset confusion	Scope inferred from similar domain name.	Only explicit IN-SCOPE assets can be tested.
Expiry not visible	Approval stored in email.	Register tracks expiry and blocks scheduling.
Excess personal data	No evidence minimization rule.	Synthetic data preferred; deletion rules added.
Missed disclosure dates	No overdue escalation.	Status alerts engagement

		lead.
External access persists	No offboarding step.	Revoke accounts and confirm evidence disposition.

9.6 Final Corrected Framework

Six gates are mandatory: request completeness; owner authorization; scope/RoE and legal/privacy review; lab/safety readiness; evidence review; coordinated disclosure and closure. Failure at any gate blocks the next phase. Exceptions require written rationale and appropriate approval but cannot override law.

REAL-TIME EXAMPLE

Shared engagement and finding IDs keep a report connected to its permission, owner, disclosure timeline and closure record. This prevents a technical finding from becoming detached from its governance history.

Evidence Produced: Integrated diagram, walkthrough, test cases and refinement table.

TASK 10 – SCALABILITY AND GOVERNANCE EVALUATION

10.1 Introduction

The following are illustrative simulated values, not measured university results. They demonstrate a reproducible way to compare a small programme with a university-wide programme.

10.2 Comparison

Table 31: Simulated Scalability Comparison

Measure	Small Programme	Large Programme	Interpretation
Systems	20	200	10× asset count.
Staff/system owners	50	500	More coordination.
Testers	2 internal	8 internal + 4 external	External onboarding needed.
Median approval	3 business days	8 business days	More reviews can delay start.
Scope coverage	95%	98%	Central inventory may improve coverage.
Steps to closure	8	10	Large programme adds vendor/review steps.
Owner assigned within 2 days	90%	96%	Central tracking supports accountability.

10.3 Reproducible Method

Assume a small programme of 20 systems, 50 staff and 2 testers; a large programme of 200 systems, 500 staff, 8 internal and 4 external testers. Assign simulated approval times of 3 and 8 days, coverage of 95% and 98%, and workflow lengths of 8 and 10 steps. Replace these assumptions with actual pilot measurements before making operational decisions.

10.4 Interpretation and Refinement

- Approval turnaround grows in the large model, so risk-based routing and standard forms are needed.
- External assessors add capacity but require contracts, onboarding, privacy checks and offboarding.
- A central dashboard can track overdue approvals without exposing sensitive evidence to every user.
- Use a streamlined path for lab-only low-risk requests; production, personal-data and third-party work receive enhanced review.

10.5 Illustrative Chart

Figure 5: Simulated approval turnaround (illustrative values)

Programme	Median Approval	Bar (1 block ≈ 1 day)
Small	3 days	■■■
Large	8 days	■■■■■■■■

Interpretation: the large programme is modelled with longer approval because it includes more systems, owners and external assessors. This supports risk-based routing; it does not predict every university's actual performance.

REAL-TIME EXAMPLE

Platforms such as HackerOne and Bugcrowd illustrate standardized scope, report intake and triage. A university should adapt these ideas only after legal review, clear scope and sufficient triage capacity.

Evidence Produced: Simulated comparison, reproducible assumptions, interpretation and governance refinement.

TASK 11 – DEFEND THE FRAMEWORK UNDER A CHANGED REQUIREMENT

11.1 Changed Requirement

The programme now needs continuous assessments, more third-party assessors, stricter data protection, shorter disclosure timelines and a design that remains governable and extendable.

11.2 Component Decisions

Table 32: Retain, Modify, Replace or Redesign

Component	Decision	Reason

Authorization	Retain; automate expiry checks.	Permission remains mandatory.
Scope/RoE	Modify.	Add recurring windows, asset IDs and third-party boundaries.
Legal/privacy review	Modify.	Add periodic review and data-classification triggers.
Threat model	Retain and refresh.	Actors and assets change over time.
Isolated lab	Modify.	Use repeatable images and snapshots.
Disclosure	Modify.	Shorter internal acknowledgement and overdue escalation.
Document library	Retain and integrate.	Shared IDs and version control.
Third-party onboarding	Add/redesign.	Identity, contract, training, scope and time-limited access.
Manual status tracking	Replace with controlled register.	Reduces missed deadlines; human review remains for high-risk decisions.

11.3 Continuous Assessor Control

Figure 6: Third-party onboarding and continuous-testing control

STEP 1	STEP 2	STEP 3	STEP 4	STEP 5	STEP 6	STEP 7
Vendor checks	Training + contract	Time-limited account	Approved asset scope	Scheduled safe checks	Triage + disclosure	Revoke access + review

Every assessor receives a unique identity and time-limited access. The asset list links to the current RoE. Scheduled checks run only against approved lab or explicitly authorized assets. Findings create tracked records. At closure, accounts are revoked and evidence retention/deletion is confirmed.

11.4 Shorter Disclosure Timeline

Set acknowledgement within one business day and immediate escalation for critical issues. Remediation targets remain risk-based because complex fixes need validation. Shorter targets must not trigger premature public disclosure or bypass law; overdue items go to the governance lead.

11.5 Evidence-Based Defence and Limitations

The walkthrough showed the value of shared IDs; the simulated scale comparison highlighted approval delays; legal mapping showed the need for personal-data review; and the disclosure process showed the need for visible deadlines. Automate routine tracking while retaining human approval for high-risk decisions.

Table 33: Remaining Trade-Offs and Future Improvements

Trade-Off / Limitation	Impact	Future Improvement
Lab realism vs containment	Lab may not match production dependencies.	Improve representative test data; approve non-destructive validation only when needed.
Speed vs legal review	Short timelines pressure reviewers.	Use templates and named on-call reviewers.
Automation vs judgement	Automation may misclassify assets.	Human approval for scope changes and external disclosure.
Continuous testing vs stability	Frequent checks may create noise.	Safe schedules, rate limits and asset exclusions.

REAL-TIME EXAMPLE

Large disclosure programmes show the value of standard intake and triage, but also the need for clear scope and enough staff. Begin with a pilot, measure false positives and overdue reports, then expand.

Evidence Produced: Component decisions, continuous-assessor diagram, revised timeline and trade-offs.

CONCLUSION

This framework combines threat classification, ethical rules, legal/privacy review, scope and RoE, written authorization, isolated-lab testing, reusable forms, coordinated disclosure, integration tests, scalability measures and continuous-assessment controls. Its central rule is that technical ability does not create permission. Every engagement must be authorized, legally reviewed, bounded, proportionate and honestly reported. Governance takes time, but protects university systems, personal data, service availability and trust.

REFERENCES

1. Government of India. Information Technology Act, 2000, as amended. India Code, Ministry of Law and Justice. Verify current text and penalties before operational use.

2. Government of India. Digital Personal Data Protection Act, 2023. India Code. Check commencement notifications and rules applicable on the engagement date.

3. Indian Computer Emergency Response Team (CERT-In). Directions under Section 70B of the Information Technology Act, 2000, 28 April 2022, and applicable updates.

4. United States Code, 18 U.S.C. § 1030. Computer Fraud and Abuse Act (CFAA).

5. Google Project Zero. Vulnerability Disclosure Policy. Consult the current official policy for deadlines and exceptions.

6. National Institute of Standards and Technology. SP 800-115, Technical Guide to Information Security Testing and Assessment, 2008.

7. OWASP Foundation. Web Security Testing Guide and related security testing documentation.

8. EC-Council. Certified Ethical Hacker (CEH) programme materials on ethical hacking and professional conduct.

9. Supreme Court of the United States. Van Buren v. United States, 593 U.S. 374 (2021).

10. Public reports and official statements about the Equifax 2017 breach, AIIMS Delhi 2022 ransomware incident, Uber 2016 breach disclosure and Coalfire/Iowa courthouse case; verify details from reliable sources before external publication.